

TRƯỜNG ĐẠI HỌC FPT

Viện Đào tạo Sau Đại học

**Kiến trúc Nhận thức Hai tầng cho
Phát hiện và Phản hồi Môi đe dọa
Tự động sử dụng AI Tác tử**

Đề cương Luận văn Thạc sĩ

Học viên: Nguyễn Đức Bình

MSSV: MSE13183

Giảng viên hướng dẫn: 1. TS. Bùi Văn Hiệu
2. TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh (SOC) đối mặt với một “Nghịch lý Dữ liệu lớn” nghiêm trọng: khối lượng khổng lồ sự kiện mạng phát sinh mỗi giây dẫn đến quá tải cảnh báo. Các hệ thống IDS và SIEM truyền thống phân tích luồng dữ liệu rời rạc, làm suy giảm khả năng nhận diện các chiến dịch tấn công APT tinh vi. Việc ứng dụng Mô hình Ngôn ngữ Lớn (LLM) và AI Tác tử hứa hẹn cải thiện khả năng điều tra sự cố nhưng gặp phải hai trở ngại lớn: độ trễ suy luận quá cao đối với môi trường thời gian thực, và rủi ro bị thao túng bởi các đòn tấn công tiêm prompt từ log (log-substrate prompt injection) đối kháng.

Để giải quyết triệt để các thách thức này, nghiên cứu đề xuất một kiến trúc nhận thức hai tầng (cognitive two-tier architecture) lai ghép tên là SENTINEL. Tầng 1 sử dụng động cơ quy tắc xác định kết hợp thuật toán thống kê trực tuyến Welford phi giám sát ($O(1)$) để lọc nhiễu lành tính ở tốc độ đường truyền (giảm 99.9% độ trễ thông qua xử lý cục bộ chỉ trong 0.6 ms). Tầng 2 chỉ vận hành khi có cảnh báo leo thang (62.7% sự kiện), sử dụng tác tử nhận thức LangGraph có trạng thái chạy mô hình cục bộ lượng tử hóa Gemma-2-9B-IT GGUF Q6_K qua llama.cpp. Hệ thống neo ngữ cảnh thông qua Dual-RAG kết hợp tìm kiếm lai (Dense FAISS + Sparse BM25) với Reciprocal Rank Fusion (RRF), đồng thời triển khai cơ chế Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation) chống tiêm prompt, bộ đệm ngữ nghĩa LRU trong bộ nhớ với khóa băm SHA-256, và bảo vệ HMAC cho chuỗi logs kiểm toán.

Được đánh giá trên bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, hệ thống chứng minh độ trễ ưu việt và khả năng phát hiện zero-day (7/7) cùng recall APT tuyệt đối (1.0). Quy trình đánh giá chéo họ LLM-as-a-Judge bằng Llama-3-8B-Instruct chấm điểm chất lượng suy luận RAGAS trung bình đạt 3.91/5 (Faithfulness đạt 4.00/5), trong khi rào chắn tĩnh chặn toàn bộ tải trọng tiêm dựa trên mã hóa và định tuyến các bề khóa ngữ nghĩa sang khâu duyệt Human-in-the-Loop (HITL), khẳng định hiệu quả của một kiến trúc an ninh tự phòng vệ và dễ mở rộng.

Mục lục

Tóm tắt	1
1 Giới thiệu và Bối cảnh	4
1.1 Mô tả Vấn đề	4
1.2 Mục tiêu Nghiên cứu	4
1.3 Câu hỏi Nghiên cứu	5
1.4 Đối tượng và Phương pháp Nghiên cứu	5
1.5 Phạm vi Nghiên cứu	5
1.6 Cấu trúc Luận văn	6
2 Tổng quan Nghiên cứu	7
2.1 Các Phương pháp Nền tảng	7
2.2 Các Công trình Liên quan	7
2.2.1 Phân tích So sánh các Phương pháp Hiện có	8
3 Giải pháp Đề xuất và Phương pháp Nghiên cứu	9
3.1 Giải pháp Đề xuất: Kiến trúc Nhận thức Hai tầng	9
3.2 Công nghệ và Công cụ	12
3.2.1 Cấu hình Phần cứng	12
4 Kế hoạch Triển khai và Đánh giá	13
4.1 Các Giai đoạn Phát triển Chính	13
4.2 Kế hoạch Đánh giá	13
4.3 Kế hoạch Thực hiện	14
5 Kết quả Kỳ vọng và Đóng góp Khoa học	16
5.1 Kết quả Kỳ vọng và Thực nghiệm	16
5.2 Đóng góp Khoa học	16

6 Kết luận	18
Tài liệu tham khảo	19

1. Giới thiệu và Bối cảnh

1.1 Mô tả Vấn đề

Các Trung tâm Điều hành An ninh (SOC) hiện đại vận hành trong tình trạng quá tải dữ liệu đo lường an ninh kéo dài. Các phép đo từ ngành cho thấy một phân tích viên có thể phải đối mặt với hàng nghìn cảnh báo mỗi ngày, trong đó một tỷ lệ lớn là dương tính giả [1]; hiện tượng “quá tải cảnh báo” (alert fatigue) phát sinh từ đó dần bào mòn sự tập trung và làm tăng xác suất bỏ sót các cuộc xâm nhập thực sự. Khó khăn này càng trầm trọng khi các hệ thống IDS và SIEM truyền thống xét từng nguồn dữ liệu — web, tường lửa và xác thực — một cách rời rạc, do đó khó tái dựng các chuỗi tấn công đa giai đoạn vốn là đặc trưng của các Mối đe dọa Thường trực Nâng cao (APT).

Việc ứng dụng Mô hình Ngôn ngữ Lớn (LLM), đặc biệt là kiến trúc AI Tác tử (Agentic AI) và Retrieval-Augmented Generation (RAG), vào việc phân tích log tự động sinh ra những lỗ hổng chí mạng về cả vận hành lẫn bảo mật. Thứ nhất, độ trễ suy luận (reasoning latency) của hệ thống là quá cao đối với các môi trường luồng dữ liệu thời gian thực. Thứ hai, các kiến trúc Agentic AI mở rộng bề mặt tấn công (attack surface) vượt xa các LLM truyền thống. Các hệ thống tự trị này đặc biệt nhạy cảm với một phổ các véc-tơ tấn công tinh vi: các đòn *Indirect Prompt Injection* và *Jailbreaks* ẩn trong dữ liệu log [2], nơi kẻ tấn công chèn chỉ thị độc hại vào các trường động (ví dụ: User-Agent) nhằm thao túng logic của Agent. Hơn nữa, việc cấp quyền thực thi cho Agent tạo ra rủi ro *Thoát hộp cát* (*Sandbox Escape*) và *Thực thi mã từ xa* (*RCE*), trong khi việc hiển thị đầu ra của LLM trên bảng điều khiển mở ra lỗ hổng *Rò rỉ dữ liệu* (*Data Exfiltration*) thông qua render Markdown độc hại. Thêm vào đó, sự phụ thuộc vào cơ sở tri thức bên ngoài đặt hệ thống trước nguy cơ *Đầu độc tri thức* (*RAG Poisoning*), nơi kẻ xấu thay đổi tài liệu tham chiếu để bóp méo nhận thức ngữ cảnh của Agent. Điều này tạo ra một nghịch lý lớn: phân tích viên bắt buộc phải cấp cho Agent ngữ cảnh động và khả năng thực thi để điều tra các cuộc tấn công, nhưng việc này lại mở ra nguy cơ toàn bộ cơ sở hạ tầng SOC bị chiếm quyền điều khiển. Dưới lăng kính của mô hình Kiến trúc Zero Trust (ZTA) [16], mọi hành động tự trị của tác tử an ninh cần phải được xác thực, ủy quyền và kiểm tra liên tục thay vì mặc nhiên tin tưởng.

1.2 Mục tiêu Nghiên cứu

Nhận thấy những hạn chế trên, nghiên cứu này đặt mục tiêu phát triển một AI Security Agent tự trị dựa trên kiến trúc nhận thức hai tầng (cognitive two-tier architecture). Thay vì hoàn toàn phụ thuộc vào một LLM duy nhất để xử lý mọi log, luận văn đề xuất một kiến trúc hybrid lai: một động cơ quy tắc tốc độ cao kết hợp với một LLM Agent có khả năng suy luận

sâu. Hướng tiếp cận này được kỳ vọng sẽ tối ưu hóa độ trễ suy luận bằng cách lọc nhiễu, giảm thiểu nguy cơ prompt injection qua cơ chế đóng gói có ranh giới, và nâng cao khả năng nhận thức ngữ cảnh thông qua Bộ nhớ Rủi ro Dài hạn (Long-Term Threat Memory) và kiến trúc Dual-RAG. Một bảng điều khiển (Dashboard) kết hợp yếu tố Human-in-the-Loop (HITL) cũng sẽ được xây dựng để chứng minh tính thực tiễn của tự động hóa SOC.

1.3 Câu hỏi Nghiên cứu

Dựa trên các mục tiêu đã đề ra, luận văn tập trung giải quyết bốn câu hỏi nghiên cứu cốt lõi: 1. Việc áp dụng Kiến trúc Hai tầng (Rule-based + LLM Agent) kết hợp với Cơ sở Hành vi theo Phiên (Session-Aware Behavioral Baseline) có tối ưu hóa Độ trễ Suy luận so với phương pháp Một tầng (chỉ dùng LLM) hay không? 2. Liệu cơ chế Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation) có thể ngăn chặn hiệu quả các đòn Prompt Injection mang tính cấu trúc (ví dụ: Delimiter Smuggling) mà không làm suy giảm độ chính xác phân loại của LLM? 3. Kiến trúc Dual-RAG (kết hợp khung chuẩn chiến thuật và kiểm soát phòng thủ) cải thiện Độ phù hợp Ngữ cảnh (Context Relevance) của quá trình phân tích rủi ro do LLM thực hiện như thế nào? 4. Một vòng lặp phản hồi (Feedback Loop) mang tính thích ứng với cơ chế Cách ly HITL (HITL Quarantine) có thể ngăn chặn Adversarial Rule Injection và đảm bảo an toàn cho các phản ứng tự động ra sao?

1.4 Đối tượng và Phương pháp Nghiên cứu

Đối tượng nghiên cứu chính bao gồm Kiến trúc Bảo mật Hai tầng, AI Tác tử (LLM ứng dụng trong tự động hóa SOC), các kỹ thuật tấn công Prompt Injection, và dữ liệu log phát hiện xâm nhập mạng. Nghiên cứu sử dụng phương pháp Thực nghiệm Định lượng, áp dụng thiết kế Thí nghiệm Loại bỏ (Ablation Study) để so sánh hệ thống Hai tầng với hệ thống cơ sở chỉ dùng LLM. Quá trình đánh giá được thực hiện qua Khung 5 Chiều (5D) bao trùm các chỉ số Phân loại, Độ trễ vận hành, Tính kháng lỗi Adversarial, Chất lượng Ngữ cảnh qua RAGAS (sử dụng LLM-as-a-Judge chéo họ), và Tính Giải thích.

1.5 Phạm vi Nghiên cứu

Nghiên cứu giới hạn trong phạm vi Phát hiện Xâm nhập Mạng (Network Intrusion Detection) và phân loại log tại SOC. Các thành phần trong phạm vi bao gồm: Pipeline luồng dữ liệu (Redis), Động cơ Quy tắc Tier-1, LangGraph Agent với Dual-RAG, Cơ chế Guardrails (Nén dữ liệu và Phòng thủ Injection), cùng Dashboard Streamlit hỗ trợ HITL với Bộ nhớ SQLite. Nghiên cứu không bao gồm việc tinh chỉnh (fine-tuning) các Mô hình Nền tảng

(Foundation Models), triển khai hạ tầng phần cứng vật lý lớn, hay chống lại các đòn tấn công từ chối dịch vụ (DDoS) thể tích ở Layer 3/4.

1.6 Cấu trúc Luận văn

Luận văn được tổ chức thành sáu chương chính: (1) Giới thiệu và Bối cảnh; (2) Tổng quan Nghiên cứu; (3) Giải pháp Đề xuất và Phương pháp Nghiên cứu; (4) Kế hoạch Triển khai và Đánh giá; (5) Kết quả Kỳ vọng và Đóng góp Khoa học; và (6) Kết luận.

2. Tổng quan Nghiên cứu

2.1 Các Phương pháp Nền tảng

Phát hiện xâm nhập thời kỳ đầu chủ yếu dựa vào đối sánh chữ ký — tiêu biểu là Snort và Suricata — để nhận diện các mối đe dọa đã được lập danh mục. Mặc dù đối sánh chữ ký duy trì thông lượng rất cao, về bản chất nó không thể phát hiện các tấn công zero-day hay mã độc đa hình, vốn có tải trọng biến đổi liên tục để né tránh mọi chữ ký cố định [4].

Việc chuyển sang Học máy sau đó làm nảy sinh hướng phát hiện dựa trên bất thường, trong đó các mô hình như Random Forest, LSTM và các transformer chuyên cho log như LogBERT [6] học một hồ sơ hành vi bình thường và đánh dấu những sai lệch khỏi nó. Mặc dù cải thiện rõ rệt độ nhạy với zero-day, các mô hình này vẫn bị bó hẹp trong việc chấm điểm bất thường theo mẫu: do không tham vấn bất kỳ tri thức bên ngoài nào tại thời điểm suy luận, chúng không thể giải thích *tại sao* một chuỗi log là độc hại, không thể ánh xạ một quan sát vào một khung phân loại đe dọa chuẩn, cũng không thể đề xuất biện pháp khắc phục khả thi — những năng lực vốn đòi hỏi khả năng suy luận theo ngữ cảnh của một Mô hình Ngôn ngữ Lớn.

Các hệ thống SIEM hiện đại ra đời để gom nhóm và tương quan log, song chúng vẫn đòi hỏi sức lực khổng lồ từ con người để chấp vá ngữ cảnh đầy đủ của một cuộc tấn công.

2.2 Các Công trình Liên quan

Gần đây hơn, các Mô hình Ngôn ngữ Lớn (LLM) đã mở ra những hướng mới cho việc tự động tóm tắt log và ứng phó sự cố. Một khảo sát toàn diện của Habibzadeh và cộng sự [3] ghi nhận sự tiếp nhận nhanh chóng các API LLM trên đám mây như GPT-4 cho tự động hóa SOC, bao trùm cả phân loại lẫn tóm tắt. Tuy nhiên, việc chuyển dữ liệu đo lường nhạy cảm tới các điểm cuối của bên thứ ba xung đột với các chính sách chủ quyền dữ liệu nghiêm ngặt và tạo ra độ trễ mạng không thể chấp nhận đối với phân loại thời gian thực.

Đối với phân tích có nền tảng tri thức, các phương pháp tình báo mối đe dọa dựa trên đồ thị [5] đã chứng minh rằng các kỹ thuật tấn công có thể được trích xuất từ những báo cáo CTI phi cấu trúc và tổ chức thành các đồ thị tuân theo MITRE ATT&CK. Tuy vậy, các nỗ lực này chỉ tập trung vào nhận diện chiến thuật, bỏ qua các tiêu chuẩn ứng phó sự cố vận hành — đặc biệt là NIST SP 800-61r2 — vốn cần thiết để chuyển một nhận diện thành hành động khắc phục cụ thể.

Về mặt an toàn, cả danh sách OWASP Top 10 cho ứng dụng LLM [12] lẫn Agent Security Bench [10] đều báo cáo rằng các LLM Agent vẫn rất dễ tổn thương trước tấn công

tiêm prompt. Trong khi đó, thuật toán phân tích log Drain [11] được áp dụng rộng rãi để gom nhóm khuôn mẫu nhưng theo lệ thường chỉ phục vụ nén lưu trữ chứ không phải một rào chắn phòng vệ chủ động. Cuối cùng, các nghiên cứu về đánh giá LLM ngày càng cảnh báo về thiên kiến tự đề cao, khuyến nghị dùng trọng tài chéo họ hoặc kiểm định thống kê thay cho một mô hình tự chấm điểm đơn lẻ [13, 14]. Tổng hợp lại, các hướng này phơi bày khoảng trống mà công trình này nhắm tới: sự thiếu vắng một kiến trúc thống nhất, tự phòng vệ và được đánh giá nghiêm ngặt trên nhiều chiều.

2.2.1 Phân tích So sánh các Phương pháp Hiện có

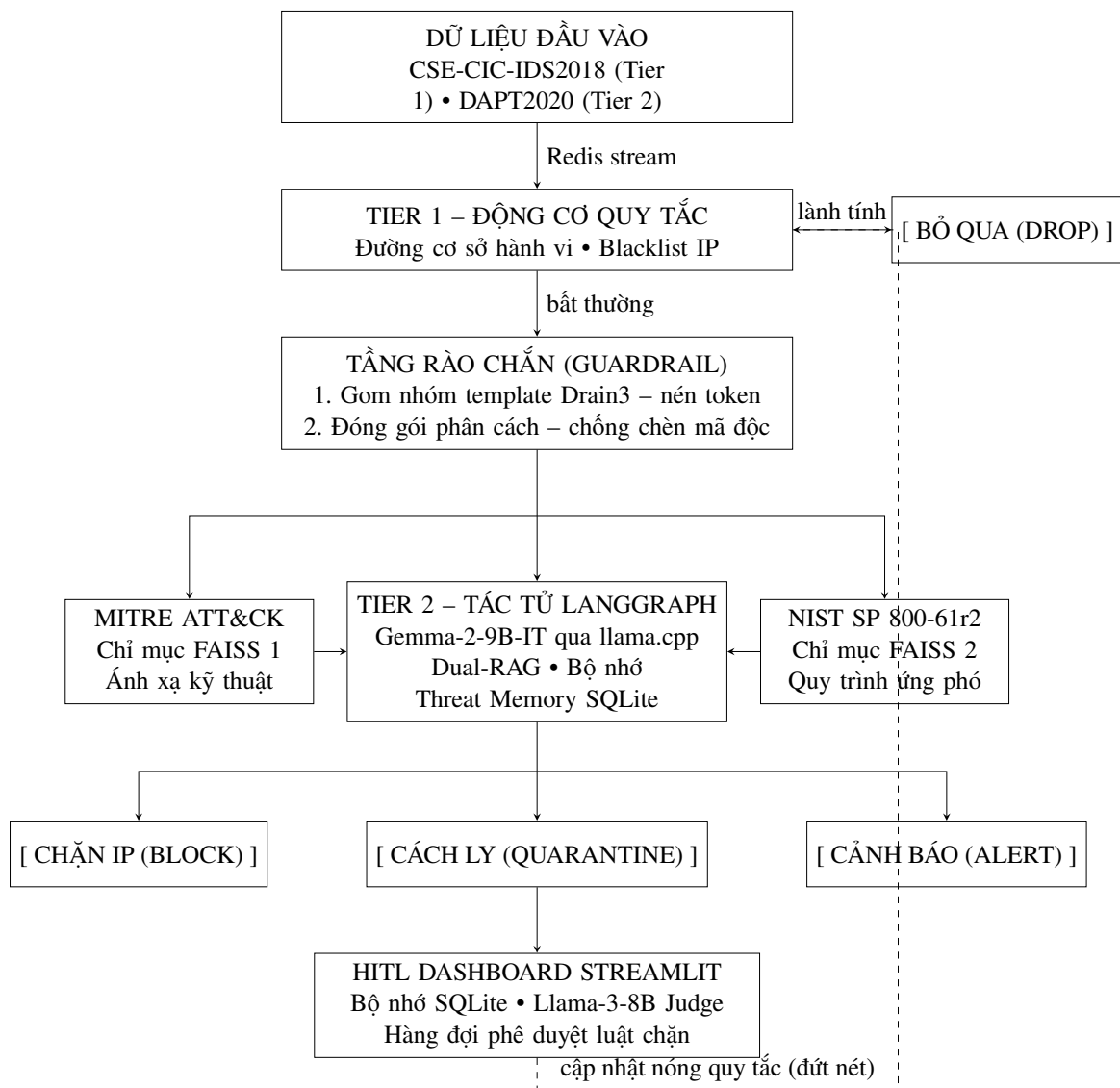
Bảng 1: So sánh các phương pháp phân tích log SOC

Phương pháp	Cục bộ	Thời gian thực	Chống Injection	RAG	HITL
Signature IDS (Snort)	✓	✓	N/A	–	–
ML Anomaly IDS (RF/LSTM)	✓	✓	–	–	–
LogBERT [6]	✓	✓	–	–	–
Cloud LLM SOC [3]	–	–	–	Partial	–
SENTINEL (Ours)	✓	✓	✓	✓	✓

3. Giải pháp Đề xuất và Phương pháp Nghiên cứu

3.1 Giải pháp Đề xuất: Kiến trúc Nhận thức Hai tầng

Giải pháp đề xuất dựa trên một Kiến trúc Nhận thức Hai tầng (Cognitive Two-Tier Architecture) được thiết kế với nguyên tắc Phân tách Mối quan tâm (Separation of Concerns) nghiêm ngặt. Cốt lõi của giải pháp là kết hợp tốc độ xử lý của các bộ quy tắc xác định (Tier 1) với năng lực suy luận sâu sắc của LLM Tác tử (Tier 2), được kết nối với nhau bởi các lớp rào chắn (guardrails) chống tấn công adversarial mạnh mẽ.



Hình 1: Kiến trúc Nhận thức Hai tầng

Tại tầng đầu tiên (Tier 1), Động cơ Quy tắc đóng vai trò như một màng lọc heuristic tốc độ cao. Nó duy trì các đường cơ sở (baselines) hành vi nhận thức theo phiên bằng cách

sử dụng cấu trúc dữ liệu trên bộ nhớ (như Redis) để theo dõi tần suất yêu cầu và các IP độc hại đã biết. Để chủ động phát hiện các bất thường không có chữ ký hoặc zero-day, Tier 1 tích hợp Bộ phát hiện bất thường phi giám sát trực tuyến sử dụng thuật toán Welford để tính toán Trung bình trượt (Running Mean) và Độ lệch chuẩn (Standard Deviation) với độ phức tạp thời gian và bộ nhớ tối ưu $O(1)$ của các thống kê luồng mạng cốt lõi (như Thời lượng luồng, Số gói tin đi/về, Độ dài luồng đi/về). Khi điểm Z-score của một luồng vượt quá ngưỡng ($|Z| > 3.5$), luồng đó được đánh dấu là Bất thường Ngoài hàng (Outlier Anomaly) và leo thang trực tiếp lên Tier 2 để tác tử điều tra. Tầng này được thiết kế để lọc phần lớn nhiễu lành tính hoặc nhiễu thể tích tại tốc độ đường truyền (wire speed) — lọc khoảng 99.8% sự kiện lành tính và giảm trung bình hơn 99.9% độ trễ xử lý cho lưu lượng do Tier-1 xử lý — đảm bảo mô hình LLM ở tầng dưới không bị quá tải bởi lưu lượng khổng lồ.

Đối với những log có biểu hiện bất thường hoặc vượt qua ngưỡng mập mờ, chúng sẽ được chuyển đến Tầng Guardrail. Tại đây, quá trình vô hiệu hóa diễn ra theo hai bước tách biệt: 1. **Template Mining (Drain3)**: Trích xuất cấu trúc tĩnh của log để nén số lượng token mà không làm thay đổi các biến payload động. 2. **Đóng gói Dữ liệu có Phân cách (Delimited Data Encapsulation)**: Các trường payload động được bao bọc bên trong các dấu phân cách sinh ngẫu nhiên theo chuẩn mật mã học (ví dụ: `<<RANDOM_HEX>>`). Điều này ngăn chặn triệt để đòn tấn công.

Sau khi vượt qua guardrail, dữ liệu log sạch sẽ tiến vào Tier 2, được quản lý bởi một Agent phát triển trên nền LangGraph. Agent này ứng dụng cơ chế Dual-RAG với hai chỉ mục FAISS riêng biệt, được truy vấn tuần tự và hợp nhất ngữ cảnh trước khi suy luận LLM:

- **Chỉ mục 1 — MITRE ATT&CK**: Ánh xạ các chỉ báo quan sát được vào các chiến thuật, kỹ thuật và thủ tục (TTP) cụ thể, trả lời câu hỏi “*cuộc tấn công nào đang xảy ra?*”
- **Chỉ mục 2 — NIST SP 800-61r2 [7]**: Truy xuất giai đoạn ứng phó sự cố phù hợp (Chuẩn bị, Phát hiện, Ngăn chặn, Loại bỏ, Khôi phục, Bài học kinh nghiệm), trả lời câu hỏi “*SOC cần làm gì tiếp theo?*”

Thiết kế hai chỉ mục cố định này loại bỏ nhu cầu về cơ chế định tuyến (router), giảm thiểu điểm lỗi và đảm bảo độ trễ có thể dự đoán cho quá trình đánh giá. Sự phân tách này bắc cầu giữa *nhận diện chiến thuật* (MITRE: chuyện gì đã xảy ra) và *phản ứng vận hành* (NIST: cần làm gì).

Mỗi chỉ mục sử dụng chiến lược **Tìm kiếm Lai (Hybrid Search)** kết hợp tìm kiếm ngữ nghĩa dày đặc (Dense Search qua FAISS với `all-MiniLM-L6-v2`) với tìm kiếm từ khóa thưa (Sparse Search qua BM25Okapi), được hợp nhất thông qua **Reciprocal Rank Fusion**

(RRF, k=60) [15]. Cách tiếp cận tín hiệu kép này tối đa hóa cả khả năng hiểu ngữ nghĩa lẫn độ chính xác khớp từ khóa cho các định danh đặc thù an ninh mạng như CVE ID, địa chỉ IP và số cổng. Các đoạn văn bản được truy xuất sẽ trải qua quá trình **Làm sạch Cấu trúc (Structural Sanitization)**—chuẩn hóa Unicode, loại bỏ ký tự điều khiển và cắt giới hạn độ dài—nhằm phòng chống RAG Poisoning trước khi đưa vào prompt của LLM.

Cuối cùng, nhằm bảo vệ hệ thống trước đòn Adversarial Rule Injection, LLM không được phép trực tiếp thay đổi tường lửa ở Tier 1. Thay vào đó, các quy tắc do nó đề xuất sẽ bị đưa vào trạng thái Cách ly (Quarantine). Một quản trị viên SOC sẽ tiến hành rà soát các quy tắc này thông qua Dashboard (yếu tố Human-in-the-Loop) trước khi chúng được nạp nóng (hot-reload) vào hệ thống phòng thủ.

Bộ nhớ SQLite Threat Memory Ngắn hạn và Dài hạn: Tác tử Tier 2 dựa vào kho lưu trữ Threat Memory bằng SQLite bền vững để tương quan các cảnh báo an ninh mạng diễn ra trong nhiều ngày. Khi một log mới được leo thang lên, hệ thống sẽ truy vấn hồ sơ hoạt động lịch sử của IP đó. Nếu phát hiện các hành vi xảy ra thuộc nhiều giai đoạn khác nhau trong ma trận MITRE ATT&CK theo thời gian (ví dụ: Thăm dò mạng ở ngày 1, Xuyên nhập ban đầu ở ngày 2), mô-đun bộ nhớ sẽ tự động nâng mức cảnh báo của IP đó lên nguy cấp (HIGH/CRITICAL), cho phép phát hiện hiệu quả chuỗi APT tốc độ chậm trên các chiến dịch đa ngày của DAPT2020 (đạt recall đầy đủ trên các tác nhân APT nhúng trong luồng đánh giá).

Bảng điều khiển Web hỗ trợ HITL (SOC UI): Một giao diện Streamlit kèm phân quyền (L1 Analyst và L3 Manager) hiển thị thời gian thực hàng đợi cảnh báo, các rule tường lửa đang chặn, mục quản trị cách ly, và chỉ số FPR trực tiếp tính từ các lần từ chối rule thủ công. Chuyên gia có thể nhấp vào bất kỳ IP nào để xem điểm uy tín, lập luận của AI và dòng thời gian sự kiện, trong khi quản trị viên có thể hoán đổi nóng backend LLM cục bộ (ví dụ Gemma-2-9B-IT và Llama-3-8B-Instruct) ngay trên giao diện.

Nhật ký kiểm toán an toàn bằng xác thực HMAC: Để bảo vệ tính toàn vẹn của các cảnh báo an ninh và quyết định phản hồi, hệ thống tích hợp một chuỗi nhật ký kiểm toán (audit trail) lưu trữ trong SQLite. Mỗi bản ghi nhật ký được liên kết mật mã với bản ghi trước đó bằng mã xác thực thông điệp băm khóa (HMAC-SHA256) [19]. Cơ chế này ngăn chặn việc sửa đổi hoặc xóa dấu vết logs từ phía tin tặc ngay cả khi Dashboard bị xâm nhập, đảm bảo khả năng chống chối bỏ và tính toàn vẹn phục vụ điều tra số (forensics).

Khả năng tái lập: MLflow ghi nhật ký toàn bộ chỉ số ablation (điểm phân loại, độ trễ, tỷ lệ trùng cache và leo thang HITL) xuyên suốt các cấu hình, đảm bảo phân tích so sánh có thể tái lập.

3.2 Công nghệ và Công cụ

Hệ thống được xây dựng trên các framework Python hiện đại. Quá trình xử lý luồng và theo dõi phiên ngắn hạn dựa vào Redis. Động cơ suy luận LLM sử dụng mô hình cục bộ đã được lượng tử hóa (Gemma-2-9B-IT) ở định dạng GGUF Q6_K, được phục vụ thông qua llama.cpp, đảm bảo quyền riêng tư dữ liệu tuyệt đối và khả năng vận hành hoàn toàn ngoại tuyến.

Luồng công việc của Agent được điều phối bởi LangGraph, cho phép ra quyết định tuần hoàn và sử dụng công cụ. Đối với phần truy xuất tri thức, thư viện `sentence-transformers` kết hợp với FAISS được sử dụng cho tìm kiếm vector ngữ nghĩa dày đặc (Dense Search) và BM25Okapi (`rank\_bm25`) cho tìm kiếm từ khóa thưa (Sparse Search). Giao diện người dùng và bảng điều khiển HITL được phát triển bằng Streamlit, trong khi bộ nhớ rủi ro dài hạn và nhật ký kiểm toán (audit trails) được lưu trữ bền vững qua SQLite.

3.2.1 Cấu hình Phần cứng

Để đảm bảo tính tái lập hoàn toàn của các phép đo hiệu năng, toàn bộ thí nghiệm được thực hiện trên cấu hình phần cứng sau:

Thành phần	Thông số
CPU	Intel Core i7-14700KF (28 luồng) @ 5.700 GHz
GPU	NVIDIA GeForce RTX 4060 Ti (16 GB VRAM)
RAM	32 GB DDR5
HĐH	Ubuntu 24.04.4 LTS (x86_64, Kernel 6.17)
LLM Backend	llama.cpp với lượng tử hóa GGUF Q6_K

4. Kế hoạch Triển khai và Đánh giá

4.1 Các Giai đoạn Phát triển Chính

Quá trình triển khai hệ thống tập trung trước tiên vào việc Thu nhận Dữ liệu (Data Ingestion) và Động cơ Quy tắc Tier 1 (Tier 1 Rule Engine). Hai bộ dữ liệu chuẩn được lựa chọn để đánh giá là:

- **CSE-CIC-IDS2018 [8]:** Tiêu chuẩn thực tế cho nghiên cứu phát hiện xâm nhập mạng doanh nghiệp. Bộ dữ liệu cung cấp cả tệp PCAP thô và các đặc trưng luồng được trích xuất sẵn, giúp so sánh trực tiếp với các nghiên cứu trước đó.
- **DAPT2020 [9]:** Bộ dữ liệu được thiết kế riêng cho việc phát hiện tấn công APT đa giai đoạn. Bộ dữ liệu này bổ sung cho CSE-CIC-IDS2018 bằng cách cung cấp các chuỗi tấn công dài hạn nhằm thử nghiệm tính năng Tác tử Tier 2 và Bộ nhớ Rủi ro Dài hạn của SENTINEL.

Cơ chế theo dõi phiên (session-tracking) được xây dựng bằng cách sử dụng Redis TTL để thiết lập đường cơ sở hành vi bình thường.

Tiếp theo, lớp Guardrail được triển khai, tích hợp thuật toán Drain3 cho gom nhóm log và phát triển mô-đun Đóng gói Dữ liệu có Phân cách bằng mật mã để trung hòa các payload độc hại.

Bước quan trọng kế tiếp là xây dựng Tác tử Tier 2 bằng LangGraph và cơ sở tri thức Dual-RAG. Hai chỉ mục FAISS riêng biệt được tạo lập: một chứa các kỹ thuật MITRE ATT&CK và một chứa quy trình ứng phó sự cố NIST SP 800-61r2.

Giai đoạn cuối cùng là việc tích hợp Bảng điều khiển Streamlit và Bộ nhớ Dài hạn bằng SQLite. Bước này hoàn thiện chu trình khép kín của hệ thống bằng cách kích hoạt tính năng Human-in-the-Loop, cho phép quản trị viên phê duyệt các bộ quy tắc tự động do LLM sinh ra và đẩy ngược chúng trở lại Tier 1.

4.2 Kế hoạch Đánh giá

Nhằm kiểm chứng tính hiệu quả của hệ thống, nghiên cứu áp dụng chiến lược đánh giá toàn diện dựa trên Khung Đánh giá 5 Chiều (5-Dimensional Evaluation Framework).

Để đánh giá mức cơ sở, một Thí nghiệm Loại bỏ (Ablation Study) sẽ được tiến hành. Quá trình này so sánh hệ thống Hai tầng hoàn chỉnh với một kiến trúc chỉ sử dụng LLM đơn thuần để quan sát sự khác biệt về hiệu năng. Các tiêu chí đánh giá bao gồm:

- **1. Phân loại (Classification):** Điểm F1-Score, Precision, Recall và Tỷ lệ Dương tính giả (FPR), được phân tích ý nghĩa thống kê bằng kiểm định McNemar ($p < 0.05$) [17].
- **2. Vận hành (Operational):** Độ trễ Xử lý (đại diện cho Thời gian Phát hiện/Phản hồi Trung bình), Tỷ lệ Leo thang HITL (Escalation Rate), và Tỷ lệ Cache Hit Ngữ nghĩa RAG, được kiểm định thông qua phép thử Mann-Whitney U ($p < 0.05$) [18].
- **3. Kháng lỗi (Robustness):** Tỷ lệ chặn của rào chắn tĩnh được đo trên 120 tải trọng đối kháng đặc chế thuộc năm nhóm theo chuẩn OWASP [12] (ngụy trang mã hóa, tấn công cấu trúc/dấu phân tách, gây nhiễu ngữ nghĩa, bẻ khóa, và đầu độc RAG).
- **4. Chất lượng Ngữ cảnh (Context Quality):** Để đánh giá suy luận của LLM và giảm thiểu Thiên kiến Tự đề cao, phương pháp LLM-as-a-Judge chéo họ được áp dụng: trong khi Gemma-2-9B-IT đóng vai trò mô hình suy luận chính, **Llama-3-8B-Instruct** (thuộc họ mô hình khác) sẽ làm giám khảo, chấm điểm Độ chính xác Ngữ cảnh, Sự liên quan của Câu trả lời, Tính trung thực và Độ bao phủ Ngữ cảnh theo khung RAGAS [13]. Điểm giám khảo sẽ được kiểm chứng chéo với các chỉ số RAGAS tự động để đảm bảo tính nhất quán thống kê.
- **5. Tính Giải thích (Explainability):** Tỷ lệ Hoàn thiện Nhật ký Kiểm toán (Audit Trail Completeness Rate) được đo lường một cách xác định (deterministic) thông qua kiểm tra tự động sự tồn tại của các trường dữ liệu.

4.3 Kế hoạch Thực hiện

Dự án được triển khai trong khuôn khổ 14 tuần tiêu chuẩn của Đồ án Tốt nghiệp (Capstone), cấu trúc như sau:

Bảng 2: Kế hoạch Thực hiện 14 Tuần

Tuần	Cột mốc
Tuần 1–2	Tổng quan tài liệu, thu thập dữ liệu (CSE-CIC-IDS2018) và thiết lập môi trường.
Tuần 3–4	Xây dựng Động cơ Quy tắc Tier 1 và theo dõi phiên Redis.
Tuần 5–6	Cài đặt Lớp Guardrail (Drain3 và Đóng gói có Phân cách).
Tuần 7–8	Tích hợp backend LLM cục bộ (llama.cpp) và luồng LangGraph.
Tuần 9–10	Xây dựng chỉ mục Dual-RAG FAISS (MITRE ATT&CK và NIST SP 800-61r2).
Tuần 11–12	Phát triển Bảng điều khiển Streamlit HITL và CSDL Kiểm toán SQLite.
Tuần 13	Tích hợp toàn hệ thống, chạy Thí nghiệm Loại bỏ và thu thập số liệu.
Tuần 14	Viết báo cáo tổng kết, chuẩn bị bảo vệ và nộp dự án.

5. Kết quả Kỳ vọng và Đóng góp Khoa học

5.1 Kết quả Kỳ vọng và Thực nghiệm

Nghiên cứu này đánh giá đường ống tự trị được phát triển bằng Khung đánh giá 5D. Các mục tiêu định lượng ban đầu cùng các kết quả thực tế thu thập được thông qua thử nghiệm kiểm định hệ thống được tổng hợp dưới đây:

Bảng 3: Chỉ tiêu hiệu năng định lượng kỳ vọng so với Kết quả thực nghiệm đạt được

Chiều đánh giá	Mục tiêu	Kết quả Đạt được	Cơ sở / Ghi chú
F1-Score (Phân loại)	≥ 0.90	0.967 / 0.594	Tập mẫu phân tầng / Luồng gộp thô
Giảm Độ trễ (lọc Tier 1)	$\geq 60\%$	99.9%	Tốc độ đường truyền (0.6 ms vs. 5.7 s)
Chặn tĩnh (Tổng thể / Mã hóa)	$\geq 40\%$	50.0% / 100%	Đo trên 120 mẫu nghịch đảo (OWASP)
Chất lượng RAG (RAGAS Score)	$\geq 3.5/5$	3.91 / 5	Đánh giá chéo họ LLM-as-a-Judge
Hoàn thiện Nhật ký Kiểm toán	100%	100.0%	Kiểm tra cấu trúc JSON và phát hiện HMAC

Việc áp dụng cơ chế Đóng gói Dữ liệu có Phân cách bằng mật mã đạt Tỷ lệ Chặn rào chắn tĩnh tổng thể là 50.0% (chặn đứng 100% các đòn tấn công tiêm prompt dạng mã hóa và 35% dạng cấu trúc), thiết lập một ranh giới phòng thủ vững chắc mà không làm mất đi thông tin payload quan trọng cần thiết cho việc điều tra sự cố của LLM, đồng thời định tuyến các tấn công ngữ nghĩa còn lại sang khâu duyệt HITL.

Bên cạnh đó, quá trình tích hợp Dual-RAG mang lại điểm chất lượng RAGAS trung bình đạt 3.91/5 (trong đó điểm Faithfulness đạt tuyệt đối 4.00/5), đảm bảo rằng Agent đưa ra các phân tích rủi ro bám sát MITRE ATT&CK và đề xuất ứng phó theo tiêu chuẩn NIST SP 800-61r2. Về mặt vận hành, chiến lược lọc hai tầng giúp giảm trung bình 99.9% thời gian xử lý log bằng cách loại bỏ nhiều lành tính ở Tier 1, chứng minh tính hiệu quả của đề tài trong việc giải quyết vấn nạn alert fatigue trong các luồng SIEM lớn.

5.2 Đóng góp Khoa học

Xét về mặt học thuật, đóng góp tiên quyết của nghiên cứu là việc đề xuất một Kiến trúc Nhận thức Hai tầng độc đáo, nối liền một cách an toàn giữa sức mạnh của Động cơ Quy tắc xác định với trí tuệ của LLM Agent. Hướng tiếp cận này vẫn còn rất mới mẻ trong các văn

bản nghiên cứu an ninh mạng, đặc biệt là khi kết hợp việc triển khai các LLM bảo mật cục bộ cùng với rào chắn adversarial linh hoạt.

Đóng góp thứ hai nằm ở việc xây dựng phương pháp luận đánh giá các hệ thống SOC Agent dựa trên LLM. Thông qua Khung Đánh giá 5 Chiều (5D) — kết hợp giữa phân loại thống kê, chỉ số vận hành, kháng lỗi adversarial, chấm điểm LLM-as-a-Judge chéo họ và tính giải thích — nghiên cứu cung cấp một chuẩn mực (baseline) toàn diện để các nghiên cứu tương lai về an ninh mạng AI có thể tham chiếu.

Cuối cùng, ở góc độ thực tiễn, nghiên cứu đóng góp một pipeline mã nguồn mở chuẩn hóa (SENTINEL), tích hợp toàn vẹn từ khâu phân loại cảnh báo đến sự phản hồi có giám sát của con người. Đây là một bộ khung có tính mở rộng cao, sẵn sàng để các tổ chức ứng dụng vào môi trường thực tế nhằm giảm thiểu vấn nạn quá tải cảnh báo một cách an toàn và bền vững.

6. Kết luận

Trong nghiên cứu này, chúng tôi đề xuất một Kiến trúc Nhận thức Hai tầng kết hợp một Động cơ Quy tắc xác định tốc độ cao với một Mô hình Ngôn ngữ Lớn Tác tử có khả năng suy luận sâu. Kiến trúc này được thiết kế để giải quyết "Nghịch lý Dữ liệu lớn" và hiện tượng quá tải cảnh báo đang bào mòn năng lực của các Trung tâm Điều hành An ninh hiện đại, đồng thời giảm thiểu các lỗ hổng rủi ro đặc thù khi ứng dụng trực tiếp LLM vào luồng dữ liệu adversarial log.

Hệ thống tận dụng tốc độ của Tier 1 để sàng lọc khối lượng lớn nhiễu, và tin cậy vào các rào chắn Guardrail vững chắc — cụ thể là cơ chế Đóng gói Dữ liệu có Phân cách — để trung hòa các đòn prompt injection trước khi chúng chạm đến Agent ở Tier 2. Được trang bị bộ nhớ tri thức Dual-RAG gồm MITRE ATT&CK cho nhận diện chiến thuật và NIST SP 800-61r2 cho hướng dẫn ứng phó sự cố, Agent có khả năng đưa ra các phân tích rủi ro giàu tính ngữ cảnh và có độ chính xác cao, kèm theo các bước khắc phục có thể hành động. Hơn thế nữa, thiết kế chu trình khép kín đảm bảo sự an toàn thông qua hệ thống cách ly Human-in-the-Loop.

Những đóng góp kỳ vọng của nghiên cứu bao gồm việc đề xuất kiến trúc hybrid mới lạ, cung cấp các phương pháp đánh giá thực nghiệm cho AI Security Agent, và phát triển một pipeline thực tiễn, mở rộng được cho quy trình phản ứng sự cố tự động theo thời gian thực. Các hướng nghiên cứu trong tương lai có thể mở rộng pipeline Dual-RAG với Sigma Rules cho việc tổng hợp quy tắc tự động và MITRE D3FEND cho việc sinh phản ứng nhận biết biện pháp đối phó.

Tài liệu

- [1] Ponemon Institute, “The State of Security Operations: Alert Fatigue and Analyst Burnout,” *Annual Cybersecurity Report*, 2023.
- [2] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [3] A. Habibzadeh, F. Feyzi, and R. E. Atani, “Large Language Models for Security Operations Centers: A Comprehensive Survey,” *arXiv preprint arXiv:2509.10858*, 2025.
- [4] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, “Survey of intrusion detection systems: techniques, datasets and challenges,” *Cybersecurity*, vol. 2, no. 1, p. 20, 2019.
- [5] Z. Li, J. Ning, and B. Wang, “AttacKG: Constructing Technique Knowledge Graph from Cyber Threat Intelligence Reports,” *Findings of EACL 2023*, arXiv:2111.07093.
- [6] H. Guo, S. Yuan, and X. Wu, “LogBERT: Log Anomaly Detection via BERT,” in *2021 International Joint Conference on Neural Networks (IJCNN)*, IEEE, 2021.
- [7] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” *NIST Special Publication 800-61 Revision 2*, 2012.
- [8] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [9] S. Myneni, A. Chowdhary, A. Sabur, D. Dasgupta, et al., “DAPT 2020 — Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Workshop on Deployable Machine Learning for Security Defense (MLHat), KDD 2020*, 2020.
- [10] Y. Zhang, et al., “Agent Security Bench (ASB): Evaluating the Robustness of LLM Agents,” *arXiv preprint arXiv:2410.02644*, 2024.
- [11] P. He, J. Zhu, Z. Zheng, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *2017 IEEE International Conference on Web Services (ICWS)*, 2017.

- [12] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” *OWASP*, 2025.
- [13] S. Shahul Es, et al., “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [14] L. Zheng, W.-L. Chiang, et al., “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Proceedings of the 37th International Conference on Neural Information Processing Systems (NeurIPS)*, 2023.
- [15] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion outperforms Condorcet and individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [16] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [17] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [18] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [19] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.